CASE STUDY

The TeamPCP Supply-Chain Campaign of 2026: Trivy, Checkmarx and the Bitwarden CLI (CVE-2026-33634)

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people this hit hardest were the engineers who run build pipelines. Trivy is the open-source scanner many teams drop into CI to find vulnerable packages, and on 19 March 2026 the scanner itself became the thing to worry about. Probably using access it kept through an incomplete clean-up of an incident that began in late February (Aqua's assessment), an attacker published a malicious Trivy release and moved almost every version tag of the official GitHub Actions that run it, so pipelines that pulled the action by tag ran a credential stealer before the real scan [1] (**Confirmed**). For hours, a trusted step in every affected pipeline was the one stealing its secrets (**Inferred**).

The stolen secrets then opened other doors. Checkmarx says the Trivy attack gave the attacker access to its GitHub repositories on the same day, which led to poisoned Checkmarx GitHub Actions and IDE extensions on 23 March and a second wave on 22 April [9] (**Confirmed**). LiteLLM believes its malicious PyPI releases of 24 March started with Trivy in its CI [12] (**Confirmed**). The European Commission's cloud hosting for Europa.eu lost about 91.7 GB, and CERT-EU assesses with high confidence that the Trivy compromise was the entry point [28] (**Confirmed**). A malicious Bitwarden CLI release on npm on 22 April is tied by Bitwarden to "a broader Checkmarx supply chain incident" [13] (**Confirmed**). Whether the same people did the April work is not settled [21] [22] (**Reported**).

Key facts at a glance

Field	Value
Primary record	GHSA-69fq-xp46-6x23 = CVE-2026-33634, critical, CWE-506 Embedded Malicious Code, CVSS v4 9.4 [1]
Second CVE	CVE-2026-42994, Bitwarden CLI 2026.4.0 on npm, CWE-78 and CWE-94, CVSS 3.1 9.8 (NVD), published 1 May 2026 [5]
KEV	CVE-2026-33634 added 26 Mar 2026, due 9 Apr, ransomware use Unknown; CVE-2026-42994 not in KEV (catalog 2026.11.10) [4] [5]
Root cause	Probable root cause (Aqua): non-atomic credential rotation after the 1 Mar disclosure may have let the attacker capture newly rotated secrets; the 19 Mar attack continued a late-February attack [1] [3]
Trivy exposure (UTC)	v0.69.4: 18:22 to about 21:42 on 19 Mar; trivy-action: about 17:43 on 19 Mar to about 05:40 on 20 Mar; setup-trivy: about 17:43 to 21:44 on 19 Mar; Docker Hub 0.69.5 and 0.69.6: 15:43 on 22 Mar to about 01:40 on 23 Mar [1]
Downstream publishes	Checkmarx actions and Open VSX extensions (23 Mar), litellm 1.82.7 and 1.82.8 (24 Mar), telnyx 4.87.1 and 4.87.2 (27 Mar), Checkmarx second wave and Bitwarden CLI 2026.4.0 (22 Apr), Checkmarx Jenkins AST plugin (9 to 10 May) [5] [9] [11] [26]
Actor	ATT&CK G1056 TeamPCP, financially motivated, active since at least September 2025 [18]; Aqua's advisory names no actor [2]
Named victim with a government record	European Commission (Europa.eu hosting): up to 71 hosting clients, about 91.7 GB compressed; disclosed 27 Mar, client communication from 31 Mar [27] [28]
Law enforcement	AFP arrested two Western Australian men on 26 Aug 2026; the FBI alleges they are TeamPCP members [16]

Key findings

- **The vulnerability is the delivery, not a bug.** NVD, GitHub and KEV file CVE-2026-33634 as CWE-506 embedded malicious code, so the fix is removal plus secret rotation, not a code patch [1] [4] (**Confirmed**).
- **The March attack was the February attack, unfinished.** Aqua says rotation after the 1 March disclosure was not atomic and the attacker may have captured newly rotated secrets [1] [3] (**Confirmed**). That is the decisive control failure in the record (**Inferred**).
- **Mutable tags were the blast radius.** 76 of 77 trivy-action tags and all 7 setup-trivy tags were force-pushed; immutable releases, switched on 3 and 4 March, protected only the releases published after that (v0.69.3 and trivy-action 0.35.0) [1] (**Confirmed**).
- **Stolen pipeline secrets became several vendors' incidents.** Checkmarx attributes its access to the Trivy attack and LiteLLM believes its compromise originated there, and the NVD record for CVE-2026-33634 lists litellm and telnyx versions in its configuration [3] [9] [12] (**Confirmed**).
- **Attribution firms up for March and blurs for April.** Checkmarx names Team PCP and Wiz ties KICS to TeamPCP by a shared RSA key [9] [10]; Bitwarden names no actor, and Socket and Sophos call the April link unresolved [13] [21] [22] (**Confirmed** for the vendor statements, **Reported** for the researchers).

Top recommendations

1. Pin every third-party GitHub Action to a full commit SHA; a version tag is a pointer the publisher (or a thief) can move [1] [3] (**Confirmed** as Aqua's and NVD's guidance).
2. Treat every secret an affected pipeline could reach as exposed and rotate it all at once, then confirm the old values are dead; Aqua says its staggered rotation may have let the attacker keep access for March [1] [3] (**Confirmed** as Aqua's assessment).
3. Hunt for `tpcp-docs` and `docs-tpcp` repositories in your GitHub organizations and review workflow logs from 19 to 20 March and 22 to 23 March [1] [10] (**Confirmed** for Aqua's guidance; the KICS name is **Reported**).
4. Prefer ephemeral runners, a least-privilege `GITHUB_TOKEN` and just-in-time secrets [15] (**Confirmed** as Microsoft's guidance); restrict runner egress to known endpoints (**Inferred**; CERT-EU advises alerting on outbound connections to unknown endpoints [28]).
5. Watch cloud control planes for API misuse and unusual traffic; SOC alerts of that kind are how the European Commission detected its intrusion on 24 March [28] (**Confirmed**), five days after the key was taken (**Inferred**).

Scope and method

This brief covers the Trivy compromise from the late-February intrusion to the August arrests, the downstream Checkmarx, LiteLLM, Telnyx and Bitwarden publishes, and the European Commission breach CERT-EU ties to it. It does not retell the Shai-Hulud worm line in npm Supply-Chain Attacks or the hackerbot-claw and LiteLLM rows in AI Threats 2026; it links them [32]. The Year 2026 in Intrusions indexes the campaign among the year's events and points here as its home study. Tradecraft is described at advisory level: no commands, payloads or file hashes are reproduced. Indicators appear only in defanged form as the advisories give them.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the affected vendor's own advisory or statement, the CVE, NVD and KEV records, a government or CERT release, and the ATT&CK object as MITRE publishes it
Reported	Third-party research or journalism about someone else's incident (Wiz, Socket, Sophos, JFrog, StepSecurity, CSA, The Record, Microsoft's campaign framing)
Demonstrated	Shown by this study's own check of the library's ATT&CK, CWE, CAPEC and D3FEND data files
Inferred	This study's own reasoning from cited facts, labelled where it appears

Times are UTC unless a source states another zone. Where sources disagree, both values are given.

Part 1: what happened

Date (2026 unless stated)	Event	Sources	Grade
Sep 2025	TeamPCP active since at least this month, per ATT&CK	[18]	Confirmed
Dec 2025	Sophos dates the group's notoriety to mass exploitation of React2Shell (CVE-2025-55182); CSA dates its first surfacing here	[23] [24]	Reported
Feb	The CipherForce ransomware brand lists six victims	[23]	Reported
21 Feb to 2 Mar	hackerbot-claw campaign hits at least seven repositories, including aquasecurity/trivy	[25]	Reported
About 28 Feb	At Trivy, a `pull_request_target` workflow yields a PAT; the repository is privatized, releases v0.27.0 to v0.69.1 are deleted and a suspicious Open VSX artifact is pushed	[7] [25]	Reported
1 Mar	Aqua's first disclosure; rotation that follows is not atomic. Trivy v0.69.2 artifacts are sigstore-signed this day	[1] [3]	Confirmed
3 and 4 Mar	Immutable releases enabled on trivy (3 Mar) and trivy-action (4 Mar), protecting v0.69.3 and trivy-action 0.35.0	[1]	Confirmed
19 Mar, about 17:43	Malicious v0.69.4 tag pushed (about 17:43), triggering the release pipeline; trivy-action and setup-trivy tags begin serving malicious commits	[1]	Confirmed (StepSecurity's branch push at the same minute Reported [7])
19 Mar, 18:22	Malicious Trivy v0.69.4 published	[1]	Confirmed
19 Mar	Checkmarx GitHub access gained; the European Commission's AWS API key obtained; Wiz sees stolen secrets validated from this day	[9] [28] [30]	Confirmed; Wiz Reported
19 Mar, 21:42 to 23:13	v0.69.4 window ends (about 21:42); clean setup-trivy v0.2.6 (21:43); setup-trivy window ends (about 21:44); Homebrew emergency downgrade (23:05); v0.69.4 tag deleted (23:13)	[1] [7]	Confirmed; minutes Reported
20 Mar	trivy-action window ends (about 05:40); Aqua opens discussion #10425; Wiz describes an actor "self-identifying as TeamPCP"	[1] [8] [20]	Confirmed; Wiz Reported
21 Mar, 15:51	Aqua publishes repository advisory GHSA-69fq-xp46-6x23	[2]	Confirmed
22 Mar	Aqua blog on the "TeamPCP Cloud stealer" label; 15:43, malicious aquasec/trivy 0.69.5 and 0.69.6 pushed to Docker Hub with separately stolen credentials (to about 01:40 on 23 Mar)	[1] [19]	Confirmed
23 Mar	Open VSX ast-results 2.53.0 and cx-dev-assist 1.7.0 live 02:53 to 15:41 (Wiz: published 12:53); ast-github-action and kics-github-action malicious 12:58 to 16:50; Checkmarx identifies the access; NVD publishes CVE-2026-33634 (22:16)	[3] [9] [10]	Confirmed

Date (2026 unless stated)	Event	Sources	Grade
23 Mar	Wiz ties the KICS compromise to TeamPCP with high confidence; repository taken down 16:50, reinstated 19:24	[10]	Reported
24 Mar	litellm 1.82.7 and 1.82.8 live from 10:39 for about 40 minutes (Wiz: about 08:30 to 11:25); Commission SOC alerts on Amazon API misuse; GitHub advisory database review (17:53); Microsoft blog	[1] [10] [12] [15] [28]	Confirmed; Wiz and Microsoft Reported
25 Mar	CERT-EU informed	[28]	Confirmed
26 Mar	CISA adds CVE-2026-33634 to KEV, due 9 Apr	[4]	Confirmed
27 Mar	The Commission publishes press release IP/26/748	[27]	Confirmed
27 Mar	telnyx 4.87.1 (03:51) and 4.87.2 (04:07) published with stolen PyPI credentials; quarantined 10:13	[26]	Confirmed
28 Mar	ShinyHunters publishes the Commission dataset	[28]	Confirmed
31 Mar	The Commission begins direct communication with affected hosting clients	[27] [28]	Confirmed
Late Mar	Vect announces a partnership with TeamPCP; exfiltration-linked infrastructure scans GKE	[15] [23]	Reported
30 Mar	Data exfiltrated from Checkmarx GitHub repositories; LiteLLM ships clean v1.83.0; Aqua updates its advisory	[2] [9] [12]	Confirmed
1 Apr	Mercor says it was "one of thousands of companies" hit by the LiteLLM compromise	[29]	Reported
22 Apr	Checkmarx second wave: KICS Docker Hub tags 12:31 to 12:59; IDE extensions from 13:06 to 17:48 (Microsoft Marketplace) and 21:20 (Open VSX); ast-github-action 2.3.35 14:17 to 15:41. Bitwarden CLI 2026.4.0 on npm 21:57 to 23:30. Last evidence of attacker activity within the Checkmarx environment, per Mandiant as Checkmarx reports it (the 9 May plugin used access obtained in March)	[5] [9] [13]	Confirmed
23 Apr	Bitwarden statement	[13]	Confirmed
25 Apr	Checkmarx data published by a criminal group (Checkmarx's timeline names LAPSUS$)	[9]	Confirmed
1 May	NVD publishes CVE-2026-42994	[5]	Confirmed
9 to 10 May	Malicious Checkmarx Jenkins AST plugin live 01:25 on 9 May to 08:47 on 10 May, using March access	[9]	Confirmed
4 Jun	Mandiant finds Checkmarx's AWS production and Checkmarx One SaaS not impacted	[9]	Confirmed
6 Jul	Checkmarx declares the incident fully contained	[9]	Confirmed
26 and 27 Aug	AFP arrests two men, aged 21 and 23; joint AFP, FBI and WA Police release	[16]	Confirmed

Discrepancies in the record

- **Tag counts.** Aqua says 76 of 77 trivy-action tags; Wiz counts 75 of 76 [2] [20] (**Confirmed**, Wiz figure **Reported**).
- **Open VSX timing.** Checkmarx gives 02:53; Wiz records a 12:53 publish [9] [10] (**Confirmed**, discrepancy unresolved).
- **LiteLLM timing.** LiteLLM gives 10:39 for about 40 minutes, with an install window to 16:00; Wiz gives about 08:30 to 11:25 [10] [12] (**Confirmed**, discrepancy unresolved).
- **Bitwarden timing.** Bitwarden says 5:57 to 7:30 PM ET, which is 21:57 to 23:30 UTC and matches NVD [5] [13] (**Inferred** conversion); forum users cite a 5:22 PM ET start [13] (**Reported**).
- **Telnyx and the CVE.** Telnyx's advisory carries no CVE id, while NVD's configuration for CVE-2026-33634 lists telnyx 4.87.1 and 4.87.2 [3] [26] (**Confirmed**, both).
- **Checkmarx entry date.** Checkmarx gives 19 March for the access in one update and 23 March as the entry in its timeline [9] (**Confirmed**, unresolved).

Part 2: the technical record

Record	Weakness and score	Affected	Fixed or safe
CVE-2026-33634 (GHSA-69fq-xp46-6x23)	CWE-506; CVSS v4 9.4, AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H	Trivy v0.69.4; trivy-action and setup-trivy tags; Docker Hub 0.69.5 and 0.69.6; NVD also lists litellm 1.82.7, 1.82.8 and telnyx 4.87.1, 4.87.2 [1] [3]	Trivy v0.69.3; trivy-action 0.35.0; setup-trivy v0.2.6 [1] [7]
CVE-2026-42994	CWE-78 (MITRE), CWE-94 (NVD); CVSS 3.1 9.8 (NVD); CVSS 4.0 8.8 (MITRE as CNA)	@bitwarden/cli 2026.4.0 from npm [5]	2026.4.1 [13]
GHSA-955r-262c-33jc	No CVE id on the advisory	telnyx 4.87.1 and 4.87.2 on PyPI [26]	not checked
PYSEC-2026-2	Credential-harvesting malware	litellm 1.82.7 and 1.82.8 [11]	v1.83.0 [12]

How v0.69.4 was built. A pushed commit pointed the release workflow's checkout step at an imposter commit that fetched malicious source from a typosquatted domain and skipped release validation; pushing the tag then ran the normal release pipeline [1] (**Confirmed**). The malicious code never reached Trivy's main branch, and an attempted v0.70.0 release was stopped [1] (**Confirmed**). The release reached the container registries, Linux packages, get.trivy.dev and Aqua's own Homebrew tap; the official Homebrew formula builds from source and was not affected [1] (**Confirmed**).

How the actions were poisoned. Rather than publish new versions, the attacker force-pushed existing tags of aquasecurity/trivy-action and replaced all seven setup-trivy tags (v0.2.0 to v0.2.6) with credential-stealing commits [1] (**Confirmed**). Any workflow that referenced a tag pulled the attacker's code on its next run (**Inferred**).

What the stealer did. The injected step ran before the legitimate scan, read runner process memory for secrets, and swept the runner's filesystem for SSH, cloud, Kubernetes, Docker, `.env`, database and wallet credentials [1] (**Confirmed**). It encrypted the haul with AES-256-CBC and RSA-4096 and sent it to attacker infrastructure, with a fallback that creates a public `tpcp-docs` repository in the victim's own GitHub account [1] (**Confirmed**). The Trivy sinks were the typosquat `scan.aquasecurtiy[.]org` and 45.148.10[.]212 [8] (**Confirmed**). ATT&CK records this payload as S9041 TeamPCP Cloud Stealer [18] [31] (**Confirmed**).

The Checkmarx variant. Wiz says 35 kics-github-action tags were hijacked through the `cx-plugins-releases` service account, with exfiltration to `checkmarx[.]zone` (83.142.209[.]11) and a `docs-tpcp` fallback repository [10] (**Reported**). Checkmarx's own windows for the actions and the Open VSX extensions are in Part 1 [9] (**Confirmed**).

The package variants. PyPA says litellm 1.82.7 and 1.82.8 followed "API Token exposure from an exploited Trivy dependency", sent data to `models.litellm[.]cloud`, persisted through a masqueraded systemd service and a Kubernetes pod, and polled `checkmarx[.]zone` [11] (**Confirmed**). Telnyx says compromised PyPI credentials were used to publish its two releases [26] (**Confirmed**). For the Bitwarden CLI, JFrog says the package ran from an npm preinstall hook, fetched the Bun runtime, harvested GitHub and npm tokens, SSH keys, cloud and Actions secrets and AI-tool and MCP configurations, and exfiltrated encrypted data to a Checkmarx-named domain with a GitHub fallback [14] (**Reported**).

After the theft. Wiz saw stolen secrets validated from 19 March, AWS discovery within 24 hours, stolen GitHub PATs used to run malicious workflows whose logs were then deleted, ECS Exec use and mass git clones, from Mullvad VPN and InterServer addresses [30] (**Reported**). At the Commission, the attacker used an AWS API key obtained on 19 March; CERT-EU found no lateral movement or website tampering [28] (**Confirmed**).

Detection content. Microsoft ships Defender antivirus signatures and a Defender for Cloud alert for this campaign [15] (**Confirmed** as Microsoft's own detections).

Part 3: who and why

ATT&CK's object. G1056 TeamPCP (aliases include PCPCat, ShellForce and UNC6780) is a financially motivated, cloud-native group active since at least September 2025 that moved in early 2026 to worm-driven credential theft and CI/CD supply-chain attacks, and that monetizes through extortion and partnerships with Vect and CipherForce [18] (**Confirmed**). Its software is S9041 TeamPCP Cloud Stealer, S9042 CanisterWorm and S9043 Mini Shai-Hulud; there is no campaign object [18] (**Confirmed**). Its references include Wiz, Aqua, Unit 42, Sysdig, Trend Micro, Google Threat Intelligence Group, Flashpoint, Hunt.io, Aikido and a 2 July 2026 FBI notice; its procedures name Trivy, KICS and LiteLLM, and the page does not name Bitwarden or the European Commission [18] (**Confirmed**).

What each party actually says.

Party	Statement	Sources	Grade
MITRE ATT&CK	G1056 TeamPCP created 16 Jul 2026, modified 2 Sep 2026	[18]	Confirmed
Aqua advisory and discussion	"a threat actor"; no name	[2] [8]	Confirmed

Party	Statement	Sources	Grade
Aqua blog	Malware labels itself "TeamPCP Cloud stealer" in a code comment; could be a false flag, but overlap with earlier tooling makes the attribution plausible	[19]	Confirmed as Aqua's statement; attribution Reported
Wiz	Actor "self-identifying as TeamPCP"; KICS is the same actor with high confidence, from a shared RSA public key	[10] [20]	Reported
Checkmarx	Access came "due to the Trivy Supply Chain Attack"; names Team PCP	[9]	Confirmed
Microsoft	"the threat actor identifying as TeamPCP"; folds in KICS, LiteLLM and, in its last update of 27 Apr, the Bitwarden CLI and checkmarx/kics Docker Hub	[15]	Reported
Bitwarden	No actor; "a broader Checkmarx supply chain incident"	[13]	Confirmed
Socket (23 Apr)	Bitwarden payload shares C2, obfuscation and structure with a Checkmarx sample, but its "Shai-Hulud: The Third Coming" branding differs; attribution unresolved	[21]	Reported
JFrog (23 Apr)	The Shai-Hulud strings do not necessarily tie TeamPCP to earlier Shai-Hulud attacks	[14]	Reported
Sophos	No intelligence connects the 22 April attacks to the March campaign; shared C2 "potentially" points to one actor	[22]	Reported
CERT-EU	Cites Aqua for the TeamPCP attribution; does not link ShinyHunters to the intrusion	[28]	Confirmed
CSA (research note, 3 Apr)	Lists CipherForce as an alias; dates the group to December 2025	[24]	Reported
Intelligence Hub	Indexes a 28 Aug news row on the arrests	[17]	Confirmed (as data)

Partners and brands. Sophos says the group appears to include people previously affiliated with The Com, ran the CipherForce brand, and partnered with Vect from late March; it confirms one Vect deployment using TeamPCP-sourced credentials and two Vect leak-site victims labelled "LiteLLM/Trivy Campaign (TeamPCP)" [23] (**Reported**). Sophos also reports a claimed LAPSUS$ partnership on Checkmarx [23] (**Reported**), and Checkmarx's timeline names LAPSUS$ as the publisher of its data [9] (**Confirmed**). CSA's alias and start date (table above) conflict with ATT&CK's [18] [24] (**Reported** conflict).

The arrests. The FBI alleges the two Western Australian men are TeamPCP members; they face 14 Commonwealth charges, including offences under Criminal Code sections 477.1 and 372.1, 478.3 and 478.4 [16] (**Confirmed**). The release names no vendor, so tying these charges to Trivy specifically is this study's inference, not the government's statement (**Inferred**).

Motive. Financial, per ATT&CK [18] (**Confirmed**); the Vect and LAPSUS$ partnerships fit that reading [23] (**Reported**).

Part 4: impact and response

Victims and sectors. The European Commission is the best-documented downstream victim: up to 71 Europa hosting clients (42 internal to the Commission, at least 29 other Union entities) and about 91.7 GB compressed taken; internal systems were not affected and the websites stayed up [27] [28] (**Confirmed**). LiteLLM, an AI gateway library, was itself compromised through Trivy [12] (**Confirmed**), and Mercor, an AI recruiting startup, called itself "one of thousands of companies" hit by that compromise; LAPSUS$'s claim of Mercor data is unverified [29] (**Reported**). The AFP release alleges more than 1,000 organizations compromised, more than 500,000 credentials stolen and at least 300 GB exfiltrated [16] (**Confirmed** as the allegation; not a verified count).

The vendors. Aqua removed the malicious artifacts, restored `latest` to 0.69.3, found no sign its commercial products were affected and engaged Sygnia [1] [8] [19] (**Confirmed**). Checkmarx released safe ast-github-action v2.3.33 and kics-github-action v2.1.20 on 23 March, deleted older tags, and reported that Mandiant found its AWS production and Checkmarx One SaaS unaffected before declaring containment on 6 July [9] (**Confirmed**). LiteLLM engaged Mandiant and rebuilt its release pipeline for v1.83.0 [12] (**Confirmed**). Bitwarden found no evidence vault data or production systems were affected and shipped 2026.4.1 [13] (**Confirmed**).

Government and regulator record. CISA added CVE-2026-33634 to KEV on 26 March as "Aquasecurity Trivy Embedded Malicious Code Vulnerability", due 9 April, ransomware use Unknown, with notes calling it a supply-chain compromise needing additional vendor guidance [4] (**Confirmed**). CVE-2026-42994 is not in KEV [5] (**Confirmed**). No NVD record names TeamPCP, and an NVD keyword search for March to June 2026 found no Checkmarx-specific CVE [6] (**Confirmed** for the search). The Commission's press release IP/26/748 and CERT-EU's post-incident blog are the only government records of the Commission breach opened for this study [27] [28] (**Confirmed**).

Part 5: the defender and vulnerability-management view

For a vulnerability-management team, this record breaks the usual loop. The KEV entry is for embedded malicious code, so there is no patched version to chase once the windows close; the work is finding whether a pipeline ran during a window and rotating everything it touched [1] [4] (**Inferred**). The KEV due date of 9 April fell about three weeks after the March windows closed (**Inferred** from [1] [4]). A scanner keyed on CVE and package version also misses the action tags, whose names never changed (**Inferred**).

Control	Where it meets the record
Pin Actions to full commit SHAs	Tag force-pushes on trivy-action, setup-trivy and kics-github-action [1] [10]
Rotate every reachable secret at once, then verify revocation	Non-atomic rotation after 1 March [1] [3]
Hunt for `tpcp-docs` and `docs-tpcp` repositories	Fallback exfiltration [1] [10]
Ephemeral runners; least-privilege `GITHUB_TOKEN`; just-in-time secrets	Microsoft's mitigations [15]

Control	Where it meets the record
Restrict runner egress to known endpoints (**Inferred**)	CERT-EU's advice to alert on outbound connections to unknown endpoints [28]
Alert on cloud API misuse and abnormal traffic	The Commission's detection on 24 March [28]
Review workflow logs and package installs inside each window	Aqua's and LiteLLM's guidance [1] [12]
Treat IDE extension marketplaces as part of the supply chain	Open VSX and Microsoft Marketplace extensions on 23 March and 22 April [9]

What is overstated and what is understated

- **Overstated:** calling this a Trivy "vulnerability" suggests a code flaw to patch; the record says malicious code delivered through stolen credentials [1] [4] (**Confirmed**). Folding the Bitwarden CLI into "TeamPCP" outruns Bitwarden, Sophos and Socket, none of which makes that attribution [13] [21] [22] (**Reported**). Scale figures such as "thousands of companies" and Vect's claim of 154 organizations are claims, not counts [23] [29] (**Reported**). Exposure windows of a few hours sound small, but the stolen secrets stay valid until rotated (**Inferred**).
- **Understated:** the compromise began in February, not March [1] [3] (**Confirmed**). CVE-2026-33634's NVD record quietly covers litellm and telnyx too [3] (**Confirmed**). Checkmarx's exposure ran from 19 March access to a 9 May plugin publish [9] (**Confirmed**). The Commission is the one downstream victim with a full government record; most victims will never disclose (**Inferred**).
- **Understated:** the campaign did not stop with Bitwarden: ATT&CK's G1056 references follow it into May 2026 waves this brief does not cover [18] (**Confirmed** as ATT&CK's references; the waves themselves not checked).

MITRE mappings

This Part binds the verified record to ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files [31] (**Demonstrated**). CERT-EU names T1586.003, T1078.004, T1195.002 and T1005 for the Commission intrusion [28], and ATT&CK's G1056 procedures cover T1677 and other rows [18] (**Confirmed**); the remaining rows are this study's mapping of the cited event (**Inferred**). CI runners, package registries and cloud accounts are not industrial control systems and no source describes an ICS effect, so no ATT&CK for ICS table applies.

Groups, software and campaigns

Object	ATT&CK id	Relationship to this record
TeamPCP	G1056	Named by Checkmarx, Aqua's blog, Wiz and Microsoft for the March activity [9] [10] [15] [19]; the FBI's alleged group [16]
TeamPCP Cloud Stealer	S9041	The self-labelled payload in the Trivy compromise [18] [19]
CanisterWorm	S9042	npm worm spreading with stolen publish tokens, per Wiz [20]
Mini Shai-Hulud	S9043	ATT&CK software of G1056 [18]; the Bitwarden payload's "Third Coming" branding is not bound to it, since JFrog and Socket do not make that link [14] [21]

ATT&CK has no campaign object for this activity [18] [31] (**Demonstrated**), so none is bound.

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1195.001	Compromise Software Dependencies and Development Tools	Initial Access	trivy-action and setup-trivy tags (19 Mar); Checkmarx actions and Open VSX (23 Mar); litellm (24 Mar); telnyx (27 Mar); Bitwarden CLI and Checkmarx second wave (22 Apr); Jenkins plugin (9 May)	[1] [5] [9] [11] [26]
T1195.002	Compromise Software Supply Chain	Initial Access	Trivy v0.69.4 release across registries (19 Mar); Docker Hub 0.69.5 and 0.69.6 (22 Mar); CERT-EU's mapping for the Commission intrusion	[1] [28]
T1677	Poisoned Pipeline Execution	Execution	Release workflow redirected to an imposter commit (19 Mar; ATT&CK's G1056 procedure names Trivy, KICS and LiteLLM, **Confirmed**); hackerbot-claw `pull_request_target` abuse (about 28 Feb, **Reported**, unattributed)	[1] [7] [18] [25]
T1078	Valid Accounts	Initial Access, Stealth, Persistence, Privilege Escalation	Compromised credentials publish v0.69.4 (19 Mar); separate Docker Hub credentials (22 Mar); `cx-plugins-releases` service account (23 Mar); PyPI credentials (27 Mar)	[1] [10] [26]
T1078.004	Cloud Accounts	Initial Access, Stealth, Persistence, Privilege Escalation	AWS API key used against the Commission (19 to 24 Mar)	[28]
T1586.003	Cloud Accounts	Resource Development	AWS API key obtained via Trivy (19 Mar)	[28]
T1098.001	Additional Cloud Credentials	Persistence, Privilege Escalation	Created and attached a new access key to an existing user (Commission, March)	[28]
T1528	Steal Application Access Token	Credential Access	PyPI token exposed through Trivy (litellm, 24 Mar); GitHub and npm tokens harvested (22 Apr)	[11] [14]
T1550.001	Application Access Token	Lateral Movement	Stolen tokens publish litellm (24 Mar); stolen GitHub PATs run malicious workflows (Wiz)	[11] [30]
T1003.007	Proc Filesystem	Credential Access	Runner process memory read for secrets (19 Mar)	[1]
T1552.001	Credentials In Files	Credential Access	Filesystem sweep for cloud, Kubernetes, Docker, `.env` and database credentials (19 Mar); AI-tool and MCP configs (22 Apr)	[1] [14]
T1552.004	Private Keys	Credential Access	SSH keys collected (19 Mar, 22 Apr)	[1] [14]
T1560	Archive Collected Data	Collection	AES-256-CBC and RSA-4096 encryption before exfiltration (19 Mar)	[1]
T1213.003	Code Repositories	Collection	Data taken from Checkmarx GitHub repositories (30 Mar); mass git clones (Wiz)	[9] [30]
T1005	Data from Local System	Collection	CERT-EU's own mapping for the Commission data theft (24 Mar discovery)	[28]
T1530	Data from Cloud Storage	Collection	Data taken from the cloud hosting Europa.eu (24 Mar discovery); CERT-EU maps this as T1005	[27] [28]

ID	Name	Tactic(s)	Dated event or report	Sources
T1041	Exfiltration Over C2 Channel	Exfiltration	Sends to `scan.aquasecurtiy[.]org` (19 Mar), `checkmarx[.]zone` (23 Mar), `models.litellm[.]cloud` (24 Mar)	[1] [8] [10] [11]
T1567.001	Exfiltration to Code Repository	Exfiltration	`tpcp-docs` fallback (19 Mar); `docs-tpcp` (23 Mar); GitHub fallback (22 Apr)	[1] [10] [14]
T1583.001	Domains	Resource Development	Typosquat and look-alike domains for Aqua, Checkmarx and LiteLLM	[8] [10] [11]
T1608.001	Upload Malware	Resource Development	Malicious builds staged on Docker Hub, PyPI, npm and Open VSX (Mar to May)	[1] [9] [11] [13]
T1105	Ingress Tool Transfer	Command and Control	Malicious source fetched at build time (19 Mar); Bun runtime fetched (22 Apr)	[1] [14]
T1176.002	IDE Extensions	Persistence	ast-results and cx-dev-assist (23 Mar, 22 Apr)	[9]
T1546.016	Installer Packages	Persistence, Privilege Escalation	npm preinstall hook in the Bitwarden CLI (22 Apr)	[14]
T1543.002	Systemd Service	Persistence, Privilege Escalation	litellm persistence (24 Mar)	[11]
T1036.004	Masquerade Task or Service	Stealth	The litellm systemd service is masqueraded (24 Mar)	[11]
T1610	Deploy Container	Execution	Kubernetes pod persistence (24 Mar)	[11]
T1580	Cloud Infrastructure Discovery	Discovery	AWS discovery within 24 hours (Wiz); GKE scanning (late Mar, Microsoft)	[15] [30]
T1070	Indicator Removal	Stealth	Malicious workflow logs deleted (Wiz)	[30]
T1651	Cloud Administration Command	Execution	ECS Exec use (Wiz)	[30]
T1485	Data Destruction	Impact	Trivy releases v0.27.0 to v0.69.1 deleted (hackerbot-claw, about 28 Feb); deletion of release artifacts by the February actor, not attributed to TeamPCP	[7] [25]

Fit notes: T1003.007 matches the advisory's description of reading runner memory through the proc filesystem [1], and ATT&CK lists it for S9041 (**Confirmed**). The remaining notes are **Inferred**. T1195.001 and T1195.002 overlap here: actions and packages are bound as dependencies and development tools, the Trivy binary release as a software supply chain. T1176.002 sits under Persistence in ATT&CK, while the record shows the extensions as a delivery route. T1530 assumes the Europa data sat in cloud storage, which CERT-EU's AWS detail supports but does not spell out; CERT-EU itself maps the theft as T1005. T1651 is an inexact fit for ECS Exec. The hackerbot-claw half of T1677 and the T1485 row are bound to the February intrusion, which StepSecurity does not attribute to TeamPCP [25]; T1485 is scored 25 and stays out of any TeamPCP-attributed summary.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-506	Embedded Malicious Code	CVE-2026-33634 (GitHub, NVD, KEV)	[1] [3] [4]
CWE-78	Improper Neutralization of Special Elements used in an OS Command	CVE-2026-42994 (MITRE as CNA)	[5]
CWE-94	Improper Control of Generation of Code	CVE-2026-42994 (NVD)	[5]

CAPEC	Name	Via	Where it meets the record
CAPEC-442	Infected Software	CWE-506; T1195.001, T1195.002	Every malicious release in Part 1 [1]
CAPEC-538	Open-Source Library Manipulation	T1195.001	litellm, telnyx and Bitwarden CLI packages [5] [11] [26]
CAPEC-670	Software Development Tools Maliciously Altered	T1195.001	Trivy, KICS and the Checkmarx IDE extensions [1] [9]
CAPEC-678	System Build Data Maliciously Altered	T1195.002	The redirected checkout in the v0.69.4 release workflow [1]

The library relates CWE-506 to CAPEC-442, CAPEC-448 and CAPEC-636; only CAPEC-442 meets this record [31] (**Demonstrated**). The CAPEC entries the library relates to CWE-78 and CWE-94 describe injection into a running program, not a malicious package, so none is bound [31] (**Inferred**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps to at least one countermeasure in the cell (from this study)	Where it meets the record
Software Inventory, Software Update, Restore Software	T1195.001, T1195.002	Auditing for v0.69.4 and moving to safe versions; `latest` restored to 0.69.3 [1]
Credential Rotation, Credential Revocation, Credential Compromise Scope Analysis	T1528, T1550.001	Rotate every secret an affected pipeline could reach [1] [3]
Outbound Traffic Filtering, Network Traffic Filtering	T1567.001, T1105	Runner egress filtering (**Inferred**) [28]
File Integrity Monitoring, System File Analysis	T1543.002	Hunting the litellm systemd persistence [11]
User Account Permissions	T1078.004	Least-privilege tokens and cloud identities for CI [15] (**Inferred** fit)

The library maps no Detect-tactic countermeasure to T1078.004, so the cloud-API anomaly alerting that detected the Commission intrusion has no D3FEND row here [28] [31] (**Demonstrated**). SHA pinning of

Actions has no direct D3FEND counterpart in the library's mappings for T1195.001 beyond Software Inventory (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/teampcp-trivy-supply-chain-2026.json` (open in Navigator). Scores: 75 for behavior in a vendor advisory, CVE record or government release; 50 for behavior known from third-party research; 25 for an inexact fit or for the February intrusion that no source attributes to TeamPCP. Each technique's comment names its source numbers.

Cross-cutting themes

- **The security tool is part of the attack surface.** A scanner runs with the same secrets as the build it scans; SolarWinds SUNBURST and the XZ Utils backdoor show the same trust in build tooling turned against its users (**Inferred**).
- **Worms and token theft are one line.** The Shai-Hulud lineage in npm Supply-Chain Attacks and the `pull_request_target` pattern recur here, and ATT&CK ties Mini Shai-Hulud to G1056 [18] (**Confirmed**); the Bitwarden payload borrows the name without a settled link [14] [21] (**Reported**).
- **AI tooling sits in the blast radius.** LiteLLM, an AI gateway, and AI-tool and MCP configurations were targets [12] [14]; AI Threats 2026 and the Hugging Face supply chain study carry that thread (**Inferred**).
- **One compromise, many extortion victims.** Partnerships with Vect and LAPSUS$ turned stolen credentials into leak-site postings [9] [23], the pattern Cl0p's file-transfer campaigns set (**Inferred**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	GitHub Advisory Database, GHSA-69fq-xp46-6x23 (CVE-2026-33634)	github.com/advisories/GHSA-69fq-xp46-6x23	2026-11-11	Confirmed
2	Aqua Security, aquasecurity/trivy repository advisory GHSA-69fq-xp46-6x23, 21 Mar 2026, updated 30 Mar 2026	github.com/aquasecurity/trivy/security/advisories/GHSA-69fq-xp46-6x23	2026-11-11	Confirmed
3	NVD, CVE-2026-33634	nvd.nist.gov/vuln/detail/CVE-2026-33634	2026-11-11	Confirmed
4	CISA, Known Exploited Vulnerabilities catalog, version 2026.11.10	cisa.gov/known-exploited-vulnerabilities-catalog?field_cve=CVE-2026-33634	2026-11-11	Confirmed
5	NVD, CVE-2026-42994	nvd.nist.gov/vuln/detail/CVE-2026-42994	2026-11-11	Confirmed
6	NVD CVE API keyword searches ("TeamPCP"; "Checkmarx supply chain", Mar to Jun 2026)	services.nvd.nist.gov/rest/json/cves/2.0?keywordSearch=TeamPCP	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
7	StepSecurity, Trivy compromised a second time: malicious v0.69.4 release	stepsecurity.io/blog/trivy-compromised-a-second-time---malicious-v0-69-4-release	2026-11-11	Reported
8	Aqua Security, Trivy discussion #10425, 20 Mar 2026	github.com/aquasecurity/trivy/discussions/10425	2026-11-11	Confirmed
9	Checkmarx, Ongoing security updates (updated 6 Jul 2026)	checkmarx.com/blog/ongoing-security-updates/	2026-11-11	Confirmed
10	Wiz, TeamPCP attack on the KICS GitHub Action, 23 Mar 2026	wiz.io/blog/teampcp-attack-kics-github-action	2026-11-11	Reported
11	PyPA Advisory Database, PYSEC-2026-2 (litellm)	github.com/pypa/advisory-database/.../PYSEC-2026-2.yaml	2026-11-11	Confirmed
12	LiteLLM, Security update, March 2026	docs.litellm.ai/blog/security-update-march-2026	2026-11-11	Confirmed
13	Bitwarden, Statement on Checkmarx supply chain incident, 23 Apr 2026	community.bitwarden.com/t/bitwarden-statement-on-checkmarx-supply-chain-incident/96127	2026-11-11	Confirmed
14	JFrog Security Research, Bitwarden CLI hijack, 23 Apr 2026	research.jfrog.com/post/bitwarden-cli-hijack/	2026-11-11	Reported
15	Microsoft Security, Detecting, investigating and defending against the Trivy supply chain compromise, 24 Mar 2026, updated through 27 Apr 2026	microsoft.com/en-us/security/blog/2026/03/24/...	2026-11-11	Reported (its own detections Confirmed)
16	Australian Federal Police, FBI and WA Police joint media release, 27 Aug 2026	afp.gov.au/news-centre/media-release/two-wa-men-charged-...	2026-11-11	Confirmed
17	Team Star Wolf Intelligence Hub feed (rows kev-CVE-2026-33634, hist-trivy-20260321 and a 28 Aug 2026 news row)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed (as data)
18	MITRE ATT&CK, G1056 TeamPCP (created 16 Jul 2026, modified 2 Sep 2026)	attack.mitre.org/groups/G1056/	2026-11-11	Confirmed
19	Aqua Security, Trivy supply chain attack: what you need to know, 22 Mar 2026, updated through 1 Apr 2026	aquasec.com/blog/trivy-supply-chain-attack-what-you-need-to-know/	2026-11-11	Confirmed (attribution Reported)
20	Wiz, Trivy compromised: TeamPCP supply chain attack, 20 Mar 2026	wiz.io/blog/trivy-compromised-teampcp-supply-chain-attack	2026-11-11	Reported
21	Socket, Bitwarden CLI compromised, 23 Apr 2026	socket.dev/blog/bitwarden-cli-compromised	2026-11-11	Reported
22	Sophos, Supply chain attacks hit Checkmarx and Bitwarden developer tools	sophos.com/en-us/blog/supply-chain-attacks-hit-checkmarx-and-bitwarden-developer-tools	2026-11-11	Reported
23	Sophos, Vect and TeamPCP partner for ransomware campaigns	sophos.com/en-us/blog/vect-and-teampcp-partner-for-ransomware-campaigns	2026-11-11	Reported

#	Source	URL	Opened	Grade
24	Cloud Security Alliance, research note on TeamPCP CI/CD supply chain attacks, 3 Apr 2026	labs.cloudsecurityalliance.org/research/csa-research-note-teampcp-...	2026-11-11	Reported
25	StepSecurity, hackerbot-claw GitHub Actions exploitation, 1 Mar 2026	stepsecurity.io/blog/hackerbot-claw-github-actions-exploitation	2026-11-11	Reported
26	Telnyx, telnyx-python advisory GHSA-955r-262c-33jc	github.com/team-telnyx/telnyx-python/security/advisories/GHSA-955r-262c-33jc	2026-11-11	Confirmed
27	European Commission, press release IP/26/748	ec.europa.eu/commission/presscorner/.../IP_26_748_EN.pdf	2026-11-11	Confirmed
28	CERT-EU, European Commission cloud breach: Trivy supply chain, 2 Apr 2026	cert.europa.eu/blog/european-commission-cloud-breach-trivy-supply-chain	2026-11-11	Confirmed
29	The Record, Mercor confirms security incident tied to LiteLLM, 1 Apr 2026	therecord.media/mercor-confirms-security-incident-tied-to-litellm	2026-11-11	Reported
30	Wiz, Tracking TeamPCP: investigating post-compromise attacks seen in the wild	wiz.io/blog/tracking-teampcp-investigating-post-compromise-attacks-seen-in-the-wild	2026-11-11	Reported
31	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), `data/weaknesses/cwe.jsonl` and `capec.jsonl`, and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
32	TeamStarWolf case studies: AI Threats 2026 and npm Supply-Chain Attacks	/case-studies/NPM_SUPPLY_CHAIN_ATTACKS.md	2026-11-11	Confirmed

Not opened, so not cited as sources: Aqua's original discussion #10265 (deleted, per [7] and [8]); Checkmarx's separate 26 March update; the Sysdig, Trend Micro and other research reports that ATT&CK cites for G1056; the FBI notice of 2 July 2026 on TeamPCP that ATT&CK cites [18]; and a scale estimate of affected organizations and pipelines seen only in a search summary.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Case studies: npm Supply-Chain Attacks, AI Threats 2026, The Year 2026 in Intrusions, XZ Utils Backdoor 2024, SolarWinds SUNBURST, Hugging Face Supply Chain, Cl0p File Transfer 2023
- Supply Chain Security, Cloud Attack Reference, Notable Incidents, Threat Actors, Malware Families
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Group: G1056 TeamPCP
- Software: S9041 TeamPCP Cloud Stealer, S9042 CanisterWorm, S9043 Mini Shai-Hulud
- Techniques: T1195.001 Compromise Software Dependencies and Development Tools, T1195.002 Compromise Software Supply Chain, T1677 Poisoned Pipeline Execution, T1528 Steal Application Access Token, T1567.001 Exfiltration to Code Repository
- Navigator layers, including this study's layer, teampcp-trivy-supply-chain-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies